

4. 身份认证

用户的身份认证是许多应用系统的第一道防线，其目的在于识别用户的合法性，从而阻止非法用户访问系统。身份识别对确保系统和数据的安全保密是极其重要的。目前，计算机网络系统中常用的身份认证方式主要有以下几种：

（1）口令认证。用户名/密码是最简单也是最常用的身份认证方法，密码是由用户自己设定的，只有用户自己才知道。只要能够正确输入密码，计算机就认为操作者就是合法用户。实际上，由于许多用户为了防止忘记密码，经常使用诸如生日、电话号码等容易被猜测的字符串作为密码，或者将密码抄在纸上，放在一个自认为安全的地方。这样，很容易造成密码泄露，即使能保证用户密码不被泄露，由于密码是静态的数据，在验证过程中需要在网络中传输，而每次验证使用的信息都是相同的，很容易被驻留在内存中的木马程序或网络中的监听设备截获。因此，从安全性上讲，用户名/密码方式是一种极不安全的身份认证方式。

（2）动态口令认证。动态口令技术是一种让用户密码按照时间或使用次数不断变化、每个密码只能使用一次的技术。它采用一种称为动态令牌的专用硬件，内置电源、密码生成芯片和显示屏，密码生成芯片运行专门的密码算法，根据当前时间或使用次数生成当前密码并显示在显示屏上。认证服务器采用相同的算法计算当前的有效密码。用户使用时，只需要将动态令牌上显示的当前密码输入计算机，即可实现身份认证。由于每次使用的密码必须由动态令牌来产生，只有合法用户才持有该硬件，所以，只要通过密码验证就可以认为该用户的身份是可靠的。而用户每次使用的密码都不相同，即使黑客截获了一次密码，也无法利用这个密码来仿冒合法用户的身份。

动态口令技术采用一次一密的方法，有效保证了用户身份的安全性。但是，如果客户端与服务器端的时间或次数不能保持良好的同步，就可能发生合法用户无法登录的问题。并且用户每次登录时需要通过键盘输入一长串无规律的密码，一旦输错就要重新操作，使用起来非常不方便。

（3）生物特征识别。生物特征识别是通过可测量的身体或行为等生物特征进行身份认证的一种技术。生物特征分为身体特征和行为特征两类，身体特征包括指纹、掌型、视网膜、虹膜、人体气味、脸型、手的血管和脱氧核糖核酸（Deoxyribonucleic acid, DNA）等；行为特征包括签名、语音和行走步态等。目前，部分学者将视网膜识别、虹膜识别和指纹识别等归为高级生物识别技术，将掌型识别、脸型识别、语音识别和签名识别等归为次级生物识别技术，将血管纹理识别、人体气味识别、DNA识别等归为深奥的生物识别技术。

9.2.3 密钥管理体制

密钥是加密算法中的可变部分，在采用加密技术保护的信息系统中，其安全性取决于密钥的保护，而不是对算法或硬件保护。密码机制可以公开，密码设备可能丢失，但同一型号的密码机仍可继续使用。然而，密钥一旦丢失或出错，不但合法用户不能提取信息，而且可能为非法用户窃取信息提供了机会。因此，密钥的管理是关键问题。

密钥管理是指处理密钥自产生到销毁的整个过程中的有关问题，包括系统的初始化、密钥的产生、存储、备份/恢复、装入、分配、保护、更新、控制、丢失、吊销和销毁等。当前，

主要的密钥管理体制有三种，分别是适用于封闭网、以传统的密钥管理中心为代表的密钥管理基础设施（Key Management Infrastructure, KMI）机制，适用于开放网的公钥基础设施（Public Key Infrastructure, PKI）机制和适用于规模化专用网的种子化公钥（Seeded public-Key, SPK）机制。

1. KMI 机制

KMI 设定一个密钥分发中心（Key Distribution Center, KDC）来负责发放密钥，这种结构经历了从静态分发到动态分发的发展过程，是密钥管理的重要手段。静态分发是预配置技术，动态分发是“请求、分发”机制，即与物理分发相对应的电子分发，一般用于建立实时通信中的会话密钥，在一定意义上缓解了密钥管理规模化的矛盾。无论是静态发放或是动态发放，都基于秘密信道（物理通道）进行，其特点归纳如表 9-1 所示。

表 9-1 KMI 密钥分发机制

分发类型	技 术	特 点
静态分发	点对点分发	可用对称加密或非对称加密实现。对称加密分发是最简单、有效的密钥管理技术，能为鉴别提供可靠的参数，但不能提供不可否认服务。有数字签名要求时，则需要用非对称加密实现
	一对多分发	可用对称加密或非对称加密实现，是点对点配置的扩展。KDC 保留所有密钥，而用户端只保留自己的密钥。这是银行清算、军事指挥、数据库系统中的主流技术，也是建立秘密通道的主要方法
	网格状分发	也称为端端密钥，可用对称加密或非对称加密实现。密钥配置量为 C_n^2 ，其中 n 为用户端的数量
动态分发	对称加密分发	首先用静态分发方式下的星形密钥配置，在此基础上解决会话密钥的分发。这种密钥分发方式简单易行
	非对称加密分发	将公私和私钥都当作秘密变量。也可以将公钥和私钥分开，只将私钥当作秘密变量，公钥当作公开变量

2. PKI 机制

PKI 是一种遵循既定标准的密钥管理平台，它能够为所有网络应用提供加密和数字签名等服务，以及所必需的密钥和证书管理体系。PKI 机制解决了分发密钥时依赖秘密信道的问题。

完整的 PKI 系统必须具有 CA、数字证书库、密钥备份及恢复系统、证书作废系统和应用接口等基本构成部分。PKI 与 KMI 的比较如表 9-2 所示。

表 9-2 PKI 与 KMI 的比较

比 较 项 目	PKI	KMI
作用特性	良好的扩展性，适于开放业务	很好的封闭性，适于专用业务
服务功能	只提供数字签名服务	提供数据加密和数字签名功能
信任逻辑	第三方管理模式	集中式的主管方管理模式
负责性	个人负责的技术体系	单位负责制
应用角度	主外	主内

PKI 的基础技术包括加密、数字签名、数据完整性机制、数字信封、双重数字签名等。其中，数字信封是用加密技术来保证只有规定的特定接收人才能阅读通信的内容。使用数字信封技术时，信息发送方采用对称密钥来加密信息内容，然后将此对称密钥用接收方的公钥加密（这部分称为数字信封）之后，将它和加密后的信息一起发送给接收方；接收方先用相应的私钥打开数字信封，得到对称密钥，然后使用对称密钥解开加密信息。这种技术的安全性相当高。

3. SPK 机制

为了更好地解决密钥管理的问题，研究人员又提出了 SPK 体系。SPK 机制可以通过以下两种方法实现：

（1）多重公钥（Lapped Public Key, LPK），用 RSA 算法实现。多重公钥有两个缺点，一是将种子私钥以原码形式分发给署名用户；二是层次越多，运算时间越长。

（2）组合公钥（Combined Public Key, CPK），用 DLP 或 ECC 实现。CPK 克服了 LPK 的两个缺点，私钥是经组合以后的变量，不暴露种子，公钥的运算几乎不占时间，是一种比较理想的密钥管理解决方案。

9.3 通信与网络安全技术

网络安全是系统的核心。计算机网络作为信息的主要收集、存储、分配、传输和应用的载体，其安全对整个系统的安全起着至关重要甚至是决定性的作用。网络安全的基础是需要具有安全的网络体系结构和网络通信协议。但遗憾的是，今天的 Internet 不论是其体系结构还是通信协议，都具有各种各样的安全漏洞，由此而带来的安全事故也层出不穷。

当然，任何一种体系结构和通信协议，都不可能尽善尽美、没有漏洞，利用网络进行的攻击与反攻击、控制与反控制永远不会停止。因此，系统分析师要熟练掌握网络安全技术，针对网络安全需求，采用相应的措施。

9.3.1 防火墙

防火墙（firewall）是一种隔离控制技术，在不同网域之间设置屏障，阻止对信息资源的非法访问，也可以阻止重要信息从内部网络中非法输出。作为 Internet 的安全性保护措施，防火墙已经得到广泛的应用。通常，企业为了维护内部的信息系统安全，在企业网和 Internet 之间设立防火墙。企业信息系统对于来自 Internet 的访问，采取有选择的接收方式。它可以允许或禁止一类具体的 IP 地址访问，也可以接收或拒绝 TCP/IP 上的某一类具体的应用。

防火墙是位于两个或多个网络之间，执行访问控制策略的一个或一组系统，是一类防范措施的总称。防火墙通常放置在外部和内部网络的中间，执行网络边界的过滤封锁机制。在某些情况下，防火墙以专门的硬件形式出现，它是安装了防火墙软件，并针对安全防护进行了专门设计的网络设备，本质上还是软件在进行控制。

1. 防火墙的功能

如果没有防火墙，整个内部网络的安全性就完全依赖于每台计算机，因此，所有的计算机

在安全水平方面都必须达到一致的高度。也就是说，整个网络的安全水平是由安全水平最低的那台计算机决定的，这就是所谓的“木桶原理”。网络规模越大，对计算机进行管理，使它们达到统一的安全水平级别就越不容易。

如果采用了防火墙，内部网络中的计算机将不再直接暴露给来自 Internet 的攻击。因此，对整个内部网络的安全管理就变成了防火墙的安全管理，这样，使安全管理变得更为方便和易于控制，也使内部网络更加安全。具体来说，防火墙一般具有访问控制功能、内容控制功能、全面的日志功能、集中管理功能、自身的安全和可用性、流量控制、网络地址转换、虚拟专用网（Virtual Private Network, VPN）等功能。

2. 防火墙的分类

从总体上来说，防火墙技术可分为网络级防火墙和应用级防火墙两类。网络级防火墙用来防止整个网络出现外来非法的入侵。例如，分组过滤和授权服务器就属于这一类。前者检查所有流入本网络的信息，然后拒绝不符合事先制定好的一套准则的数据；而后者则检查用户的登录是否合法。应用级防火墙由应用程序进行接入控制，通常使用应用网关或代理服务器来区分各种应用。例如，可以只允许 WWW 应用，而阻止 FTP 应用。

在实际应用中，可以根据不同的应用对防火墙进行更加详细的划分，一般可以分为包过滤型防火墙、电路级网关型防火墙、应用网关型防火墙、代理服务型防火墙、状态检测型防火墙和自适应代理型防火墙。

3. 防火墙的体系结构

从体系结构上看，防火墙可以有多种实现模式，例如，宿主机模式、屏蔽主机模式和屏蔽子网模式等。

（1）双宿/多宿主机模式。双宿/多宿主机模式是一种拥有两个或多个连接到不同网络上的网络接口的防火墙，如图 9-1 所示。通常用一台装有两块或多块网卡的堡垒主机做防火墙，两块或多块网卡各自与内部网和外部网相连，一般采用代理服务的办法，必须禁止网络层的路由功能。



图 9-1 双宿/多宿主机模式

（2）屏蔽主机模式。屏蔽主机模式的防火墙由包过滤路由器和堡垒主机组成，如图 9-2 所示。

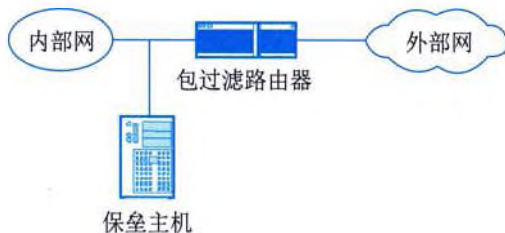


图 9-2 屏蔽主机模式

屏蔽主机模式的主要特点是，在防火墙中，将堡垒主机安装在内部网络上，通常在路由器上设立过滤规则，并使这个堡垒主机成为从外部网络唯一可直接到达的主机，这确保了内部网络不受未被授权的外部用户的攻击。屏蔽主机防火墙实现了网络层和应用层的安全，因此比单独的包过滤或应用网关代理更安全。在这种模式下，过滤路由器是否配置正确是防火墙安全与否的关键，如果路由表遭到破坏，堡垒主机就可能被越过，使内部网完全暴露。

(3) 屏蔽子网模式。屏蔽子网模式采用了两个包过滤路由器和一个堡垒主机，在内外网络之间建立一个被隔离的子网，称为非军事区（Demilitarized Zone, DMZ）或边界网络（Perimeter Network），如图 9-3 所示。



图 9-3 屏蔽子网模式

屏蔽子网模式的特点是，网络管理员将堡垒主机、Web 服务器、Mail 服务器等公用服务器放在 DMZ 中。内部网络和外部网络均可访问屏蔽子网，但禁止它们穿过屏蔽子网通信。在这一配置中，即使堡垒主机被入侵者控制，内部网仍能受到内部包过滤路由器的保护。多个堡垒主机运行各种代理服务，可以更有效地提供服务。

当然，防火墙还可能存在着其他的结构模式，例如，一个堡垒主机和一个 DMZ、合并 DMZ 的内部路由器和外部路由器、使用多个堡垒主机、使用多重宿主机与屏蔽子网等。在实际应用中，需要按照网络环境的要求来构造防火墙。

4. 防火墙的局限性

防火墙对企业内部网实现集中的安全管理，可以强化网络安全策略，能防止非授权用户进入内部网络，可以方便地监视网络的安全性并报警，可以作为部署 NAT 的地点，利用 NAT 技术，缓解地址空间的短缺，隐藏内部网的结构。同时，由于所有的访问都必须经过防火墙，因此，防火墙是审计和记录网络的访问和使用的最佳措施。然而，防火墙的使用也有一定的局限性，列举如下：

(1) 为了提高安全性，限制或关闭一些有用但存在安全缺陷的网络服务，给用户带来了使用上的不便。

(2) 目前，防火墙对于来自网络内部的攻击还无能为力。作为一种被动的防护手段，防火墙不能阻止 Internet 不断出现的新的威胁和攻击，不能有效地防范数据驱动式攻击。

(3) 防火墙不能防范不经过防火墙的攻击，例如，内部网用户通过串行线路网际协议（Serial Line Internet Protocol, SLIP）或点对点协议（Point to Point Protocol, PPP）直接进入 Internet。